

#22 · 軟刪除

[優化] 技術代號 D-PO-2 · 約 3-4 天

一句話：誤刪無法救回

為什麼要修

刪除就是直接從資料庫 DELETE。

現在怎樣

無 deletedAt 欄位、無 GDPR 合規入口、誤刪只能 from backup 救（沒做 PITR）。

問題在哪

使用者誤刪一個專案就永久消失、客服處理困難、GDPR 風險。

要改什麼

對 12 張關鍵表加 deletedAt 欄位、新增 whereActive helper、Repository 預設套用 filter、新增 GDPR DSR endpoint + 30 天硬刪 worker。

涉及檔案

drizzle/migrations/00XX_soft_delete_columns.sql (新增)

drizzle/schema.ts (12 張表加 deletedAt)

server/repositories/base/SoftDelete.ts (新增 whereActive / softDelete helper)

server/routes/dsr.ts (新增 POST /api/account/dsr-erase)

server/jobs/gdprPurgeWorker.ts (新增 30 天硬刪 worker)

Claude Code 提示詞 (複製貼上)

把下面這段話完整複製，貼到 Claude Code (或 /claude 對話)。Claude Code 會依此完成此項修復。完成後跑下方驗證步驟確認。

請依照計畫附錄 A.9 實作 D-PO-2 軟刪除 + GDPR 入口：

【第 1 部分：Schema 加欄位】

1. 新增 migration drizzle/migrations/00XX_soft_delete_columns.sql (取下一可用編號)：

對下列 12 張表各加 deleted_at TIMESTAMP NULL 與 INDEX idx_XXX_deleted_at (deleted_at)：

- users
- agentCollaborationSessions
- orbConversations
- orbConversationMessages
- orbLongTermMemories
- generationHistory
- digitalAssetLibrary
- fineTunedModels
- orbScheduledJobs
- teachingMaterials
- projectNotesCalendar
- featuredShowcase

ALTER TABLE 不設 default (避免鎖表)：

```
```sql
ALTER TABLE users ADD COLUMN deleted_at TIMESTAMP NULL;
CREATE INDEX idx_users_deleted_at ON users (deleted_at);
-- 其餘 11 張同樣 pattern
```
```

2. 修改 drizzle/schema.ts 對應 12 張表加 deletedAt: timestamp("deleted_at")。

【第 2 部分：helper】

3. 新增 server/repositories/base/SoftDelete.ts：

```
```typescript
import { sql, type SQL } from "drizzle-orm";

export function whereActive<T extends { deletedAt: any }>(tb: T): SQL {
 return sql`${tb.deletedAt} IS NULL`;
}
```

```
export async function softDelete<T extends { deletedAt: any }>(table: T, whereClause: SQL, db:
DrizzleDB) {
 await db.update(table).set({ deletedAt: new Date() }).where(whereClause);
}

```

### 【第 3 部分：repository 預設套用】

4. 修改既有 repository (UserAuthRepository、SpiritMemoryRepository 等) 的 find / list 方法：預設套 whereActive(table)。對需要看到被軟刪除資料的場景 (admin / restore flow) 提供顯式 opt-out。

### 【第 4 部分：GDPR DSR endpoint】

5. 新增 server/routes/dsr.ts：

```
```typescript
POST /api/account/dsr-erase
Auth required.
Steps:
1. 軟刪 users + 所有 user-owned 列 (透過 cascade 或顯式逐表)
2. 排程 30 天後 hard-delete worker (寫一筆 task 到 backgroundJobs 表, jobType="gdpr_purge",
scheduledFor=Date.now()+30天)
3. appendAuditLog({ userId, action: "dsr_erase_initiated", details: { scheduledPurgeAt } })
4. 回傳 confirmation + 撤回 link (30 天內可呼叫 dsr-revoke)
```
```

### 【第 5 部分：硬刪 worker】

6. 新增 server/jobs/gdprPurgeWorker.ts (cron 每日 03:00)：

- 找所有 gdpr\_purge task scheduledFor < now()
- 對每個對象實際 DELETE FROM 所有 user-owned 表 (不能再回滾)
- 寫 audit log gdpr\_purge\_completed

不要做的事：不要在 DELETE FROM 上加觸發器自動軟刪 (複雜、容易出 bug)。不要對「無使用者主權」的表加軟刪 (如 newsArticles)。不要實作 hard restore (軟刪後刪除 deletedAt 即可)。

## 如何驗證做完了

建一個測試帳號 → 建一個 generation → 呼叫 DELETE → 看 SQL：該 row 仍存在但 deletedAt IS NOT NULL → UI 看不到。修改 deletedAt = NULL → UI 又看到。呼叫 dsr-erase → 30 天後 hard delete 真正清除。

## 預估耗時

3-4 天